OWASP crAPI

LOCAL API SECURITY ASSESSMENT

Prepared: 2026-10-29 | Assessment type: Time-boxed educational lab VAPT

LIMITED ASSESSMENT - ONE FINDING VERIFIED

This assessment tested the locally hosted OWASP crAPI training application using two test accounts. Testing confirmed that one signed-in account could retrieve another account's vehicle location and owner details by using that vehicle's identifier. This could expose a person's location information and identifying details in a real deployment. The assessment was limited to the local lab; other vulnerability categories remain untested.

1. Scope and methodology

Scope note: Assessment performed against a locally hosted instance of OWASP crAPI, an intentionally vulnerable application, for educational purposes. No production or third-party systems were tested.

Target: http://127.0.0.1:8888 in Docker Compose inside the Kali VM. MailHog was available at http://127.0.0.1:8025. Nmap was run against 127.0.0.1 only; observed Compose port bindings were on loopback.

Methodology: Reviewed the OpenAPI specification and Postman collection, identified listening TCP ports with Nmap service detection, then performed authenticated cross-account testing. User A owned the vehicle; User B made the request with its own bearer token.

Limitations: Time-boxed work. JWT forgery, mass assignment, OTP/rate limiting, SSRF, and other BOLA/BFLA scenarios were not assessed. The 44221 loopback listener was attributed by ss to containerd, but its purpose was not established. Results describe the observed crAPI build and lab state only.

2. Findings summary

#	Title	Severity	CVSS	Status
1	Cross-account access to vehicle location (BOLA)	Medium	4.3	Verified

3. Detailed finding

1. Cross-account access to vehicle location (BOLA)

Severity: Medium | CVSS v3.1: 4.3 | Vector: AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

Affected endpoint: GET /identity/api/v2/vehicle/{vehicleId}/location

OWASP: API1:2023 Broken Object Level Authorization | CWE-639: Authorization Bypass Through User-Controlled Key

Description

The endpoint returned a vehicle-location object when called by an authenticated account that did not own the referenced vehicle. The response also included the vehicle owner's name and email. The tester authenticated as User B and requested a UUID belonging to User A; the API returned HTTP 200 with location and owner fields.

Proof of concept

1. Authenticate as User A and add a vehicle in the local crAPI lab.
2. Capture the UUID in User A's location request.
3. Authenticate as User B and send GET /identity/api/v2/vehicle/{User-A-vehicle-UUID}/location using User B's bearer token.
4. Observe HTTP 200 and a response containing the vehicle location and User A's owner details.

Evidence: See PDF Appendix, Exhibits 1-3. The screenshots omit the bearer token and mask or exclude precise response data.

Business impact

In a real deployment, an ordinary authenticated user could access another customer's vehicle location and identifying details. Repeated access to vehicle identifiers could enable unauthorized tracking or disclosure of personal information.

Remediation

Enforce object-level authorization on every vehicle-location request. Resolve the authenticated principal from the validated token and query the vehicle using both its identifier and owner identity. Return 403 Forbidden or a non-enumerable 404 Not Found for vehicles not owned by the caller. Add regression tests for cross-account reads and writes across vehicle endpoints.

4. Appendix

Tools and data sources

Kali Linux VM; Docker Engine and Compose; Nmap 7.99; browser Developer Tools; curl; OWASP crAPI OpenAPI specification and Postman collection; FIRST CVSS v3.1 calculator.

Timeline

Phase	Activity	Result
Setup	Installed Docker and started crAPI Compose stack	Services running; app reachable
Recon	Loopback TCP scan and OpenAPI inventory	Seven listeners and 43 operations recorded
Manual testing	Cross-account vehicle-location check	One BOLA finding verified
Tooling	Prepared httpx/Rich BOLA checker	Requires local run with tester credentials

BOLA checker output

The checker is configured to fetch User A's vehicle list, extract a vehicle UUID, then request its location using User B's token. Record actual run output here after running it in Kali; this report does not claim an automated run result.

Appendix: Screenshot Evidence

Sanitized copies for portfolio use; original captures were not modified.

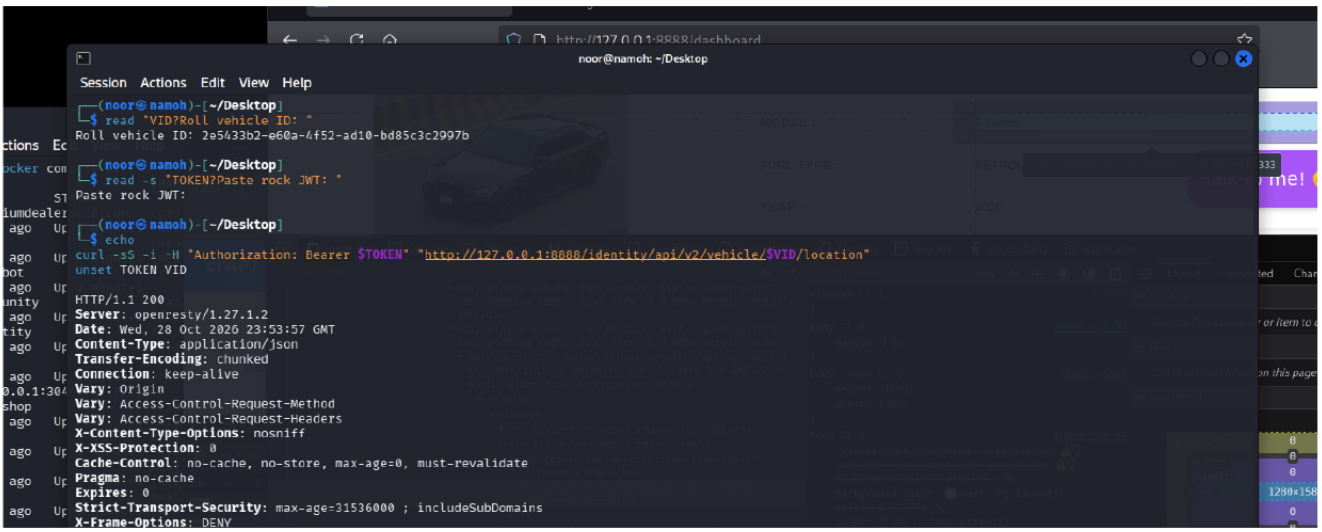


Exhibit 1 Terminal shows HTTP 200; response body is excluded from this public copy.

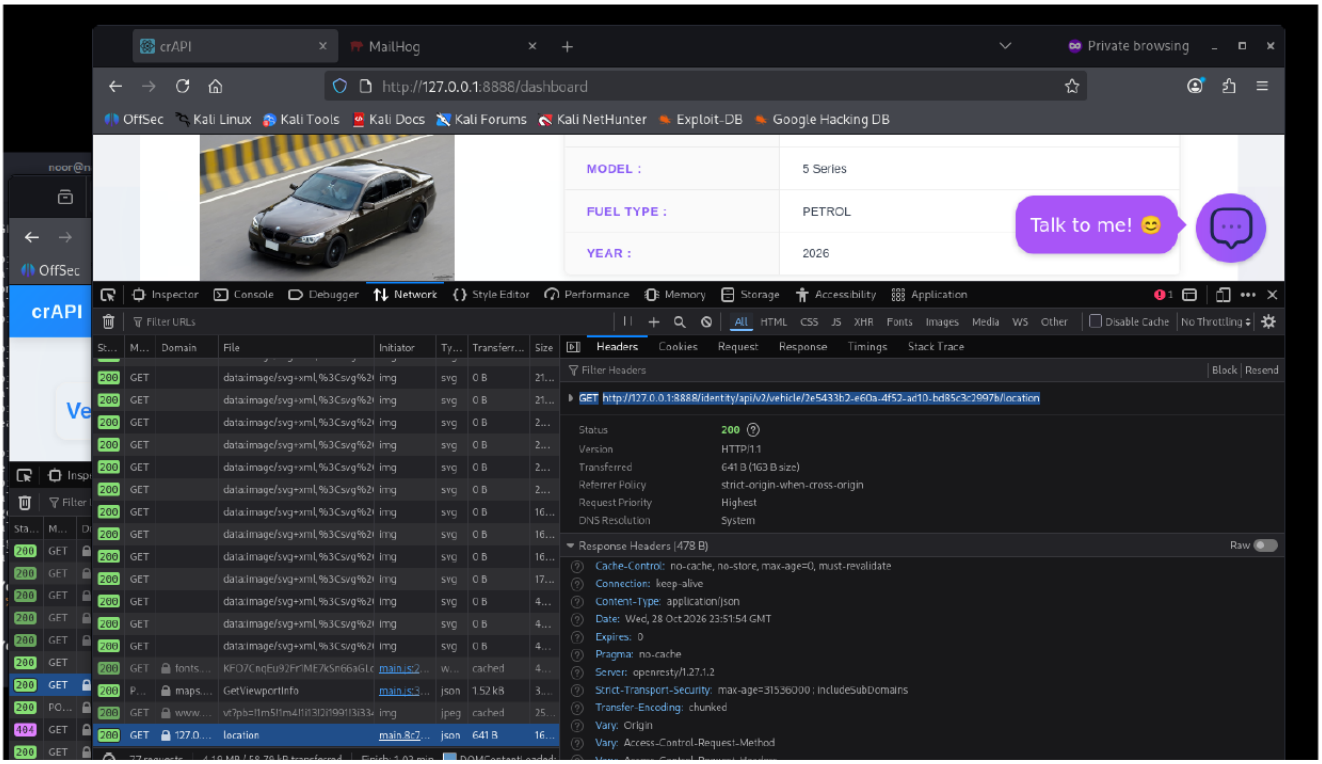


Exhibit 2 Vehicle-location request path and HTTP 200 status in Developer Tools.

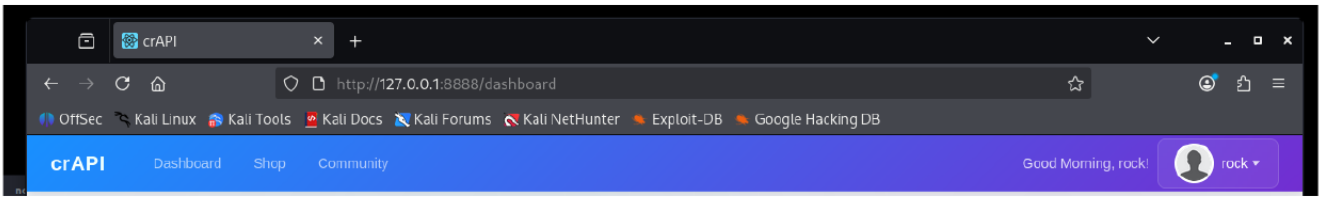


Exhibit 3 User B session context; crop excludes the bearer authorization header.